

GDPR Privacy Audit Pack

EU Tender Autonomous Agent

Walid Barakat | i@work UG

24 August 2026

Go with conditions

Human-supervised EU tender decision support

Audit contents

1	GDPR Privacy Audit Pack: EU Tender Autonomous Agent	2
1.1	Section 1: Audit worksheet	2
1.1.1	1. Transition from the EU AI Act assessment	2
1.1.2	2. Fact pattern	3
1.1.3	3. System and data-flow summary	3
1.2	Section A: Data map	3
1.2.1	A1. Categories of personal data	3
1.2.2	A2. Sources	4
1.2.3	A3. Purposes, lawful bases and retention	4
1.2.4	A4. Recipients, processors and subprocessors	5
1.2.5	A5. International transfers	6
1.3	Section B: Risk and rights	6
1.3.1	B1. Article 9 special-category data	6
1.3.2	B2. Article 22 automated decision-making	6
1.3.3	B3. DPIA screening against the nine EDPB criteria	6
1.3.4	B4. Likely data-subject friction points	7
1.3.5	B5. Controller and processor split	7
1.3.6	B6. Data Processing Agreements	7
1.4	Section C: Law stacking	8
1.4.1	C1. AI Act cross-check	8
1.4.2	C2. ePrivacy check	8
1.4.3	C3. Data Act check	8
1.5	Section 2: Client recommendation memo	8
1.5.1	To: Management and Technical Lead, i@work UG	8
1.5.2	Subject: GDPR readiness of the EU Tender Autonomous Agent	8
1.6	Reinforcement materials	9
1.7	Appendix: Blank Partner Peer Review Rubric	10
1.7.1	Option B - Start fresh with a new scenario	10
1.7.2	Scenario commitment	10
1.7.3	Shared fact pattern	10
1.7.4	Review record	10
1.7.5	Scoring rubric	10
1.7.6	Client response	11
1.7.7	Debrief	11
1.7.8	Author response to feedback	11
1.8	References	11

1 GDPR Privacy Audit Pack: EU Tender Autonomous Agent

Prepared for: i@work UG

Prepared by: Walid Barakat

Date: 24 August 2026

Recommendation: Go with conditions

Educational consulting analysis based on the stated fact pattern. Final production decisions should be confirmed by qualified legal counsel and the responsible controller.

1.1 Section 1: Audit worksheet

1.1.1 1. Transition from the EU AI Act assessment

The same EU Tender Autonomous Agent assessed in the earlier AI Act exercise is carried forward for this GDPR audit. In its current configuration, it is a professional decision-support system used to research EU energy tenders and recommend whether i@work should pursue them. It does not fall within an Annex III high-risk category and does not decide a natural person's access to employment, credit, education, public services or another legally significant opportunity. It is therefore best treated as a minimal-risk business system, with Article 50 transparency duties where a user interacts directly with an AI interface or receives AI-generated content requiring identification. The

GDPR analysis remains necessary because the workflow can process identifiable tender contacts, users, experts, document authors and operational identifiers.

1.1.2 2. Fact pattern

i@work UG is a small German energy and AI consultancy operating the EU Tender Autonomous Agent. The nine-stage system retrieves EU energy tender records, validates and triages them, gathers additional evidence through ReAct tools, uses Pinecone-supported retrieval, performs technical, financial, risk and compliance analysis, and produces an advisory bid or no-bid recommendation for human approval. Personal data can include public professional names and email addresses, user-account identifiers, IP addresses, workflow logs, named experts and personal information contained in tender documents. Most data subjects are located in the EU or EEA, although public sources and consortium material may involve third countries. The stack may use non-EU vendors for LLM processing, vector storage, collaboration, publication and network access. The final recommendation concerns i@work's commercial choice, not a legally significant decision about an individual.

1.1.3 3. System and data-flow summary

System flow

EU portals and documents to n8n control plane to FastAPI agent boundary to LLM, tools and Pinecone to human-approved report to Notion, Slack, Drive and PDF.

The control plane schedules calls, validates inputs, branches, retries, loops and publishes results. The external agent boundary owns ReAct tool selection, LangGraph state transitions, MCP/API tool exposure and RAG retrieval. This distinction matters because personal data can be copied at both layers.

1.2 Section A: Data map

1.2.1 A1. Categories of personal data

Category	Examples	Sensitivity and audit treatment
Public professional identifiers	Tender contact name, work email, job title, professional affiliation	Personal data even when publicly available; minimise downstream reuse
User and administrator data	Name, account ID, email, role, authentication metadata	Required for authorised system operation; restrict access
Technical identifiers	IP address, device or session identifiers, request timestamps, API logs	Personal data when linked or reasonably linkable to a user
Document-level personal data	Authors, project officers, experts, CV details, signatures and contact information	May be necessary for tender interpretation, but not for every processing stage
Generated or inferred data	Notes or scores that refer to a named expert or contact	Can become personal data and may be inaccurate or unfair
Communication and publication metadata	Slack user ID, Notion editor, Drive recipient, report author	Limit to operational need and apply workspace access controls
Special-category data	Not intentionally collected; health, ethnicity, political opinion or disability may appear incidentally in CVs or biographies	Detect, quarantine and remove unless a documented Article 9 condition exists

Company names, tender budgets and information relating only to legal persons are not personal data by themselves. Information relating to identifiable employees or representatives remains personal data.

1.2.2 A2. Sources

Source	Typical data
EU Funding and Tenders Portal and SEDIA search services	Tender metadata, named contacts, deadlines and documents
CORDIS, data.europa.eu and official programme sources	Project, organisation, researcher and policy information
Official news and web sources used by acquisition tools	Public professional and organisational evidence
i@work or client input	Company profile, evaluation criteria, named team members and internal notes
n8n, FastAPI and infrastructure logs	Requests, timestamps, IP addresses, error details and user identifiers
LLM, retrieval and vector systems	Prompts, retrieved passages, embeddings, outputs and trace metadata
Notion, Slack, Google Drive and generated PDFs	Report contents, recipients, editors, notifications and audit receipts

1.2.3 A3. Purposes, lawful bases and retention

The periods below are proposed design limits, not evidence of already configured deletion. They require controller approval and technical implementation.

Purpose	Data used	Proposed Article 6 basis	One-line justification	Proposed retention
Discover and assess relevant tenders	Public professional contacts and tender-document identifiers	Legitimate interests, Article 6(1)(f)	i@work has a concrete business interest in identifying tender opportunities, provided the LIA confirms limited impact and reasonable professional expectations	Tender lifecycle plus 24 months for decision history, with contact fields removed earlier when no longer needed
Provide a contracted assessment service	Client-provided users, instructions and deliverables	Contract where processing is objectively necessary for a contract with the data subject; otherwise legitimate interests or TBD legal review	A corporate service contract alone does not automatically justify processing every employee's data under Article 6(1)(b)	Contract term plus the approved claims and records period
Maintain security, reliability and troubleshooting	Account, request, IP and error-log data	Legitimate interests, Article 6(1)(f)	Limited security logging is necessary to protect the service, investigate failures and prevent misuse	90 days by default, longer only for a documented incident or legal need
Generate and deliver the human-reviewed report	Tender evidence and limited named professional information	Legitimate interests and, where applicable, contract	The report serves the documented tender-assessment purpose and should contain only information necessary for that purpose	Active tender plus 24 months, followed by deletion or de-identification
Notify authorised project members	Recipient identifiers and report status	Legitimate interests and, where applicable, contract	Notifications are necessary for authorised collaboration and completion evidence	Collaboration-workspace retention policy, reviewed at project closure

Purpose	Data used	Proposed Article 6 basis	One-line justification	Proposed retention
Improve or train a general model using accumulated prompts or documents	Prompts, source passages, outputs and feedback	TBD: legal review before any reuse	Model improvement is a separate purpose and must not be assumed from access to operational data	No training or improvement reuse until a compatible purpose and lawful basis are documented

1.2.3.1 Legitimate Interests Assessment summary

1. **Purpose:** The business-research and system-security purposes are specific and lawful.
2. **Necessity:** The system should process organisation-level information and tender identifiers where possible. Names, emails and free-text personal details should be removed before LLM and vector processing unless essential.
3. **Balancing:** Tender contacts can reasonably expect limited professional use of published contact information, but not unrestricted model training, indefinite retention, sensitive inference or mass redistribution. Minimisation, restricted access, source links, retention and objection handling are required safeguards.

1.2.4 A4. Recipients, processors and subprocessors

Entity or category	Likely role	Required action
i@work using the system for its own tender decisions	Controller	Approve purposes, lawful bases, retention, notices and safeguards
Client instructing i@work to run assessments	Client is normally controller; i@work may be processor	Document instructions and execute an Article 28 DPA
i@work when it independently determines product analytics or model-improvement purposes	Controller for that separate purpose	Conduct a separate lawful-basis and transparency analysis
EU portals and other source publishers	Separate controllers for their source services	Respect source terms and avoid assuming public means unrestricted
Self-hosted n8n and FastAPI	Part of i@work's processing environment	Apply access, logging, patching, backup and retention controls
Hosting provider, if infrastructure is externally hosted	Processor	DPA, hosting-location assessment and security review
Configured LLM provider, such as Anthropic or OpenAI where enabled	Processor or subprocessor for instructed prompts, subject to actual terms	DPA, no-training setting, retention control and transfer review
Pinecone	Processor or subprocessor for vector content	DPA, regional configuration, namespace isolation and deletion testing
Notion, Slack and Google Drive	Processors or subprocessors for collaboration and publication	DPA, recipient restrictions, workspace access review and transfer assessment
Cloudflare or tunnel/network provider	Processor for relevant traffic and metadata, depending on service	DPA, configuration and transfer assessment

Roles are functional and must be verified against actual contracts and data uses. A vendor that decides to reuse prompts for its own purposes may be a separate controller for that processing.

1.2.5 A5. International transfers

Transfer issue	Audit answer
Does data cross the EEA border?	Potentially yes, through non-EU vendors, subprocessors, support access or global collaboration services
Primary mechanism	Verify whether each US recipient has active EU-US Data Privacy Framework certification covering the relevant service and data type
Alternative mechanism	European Commission Standard Contractual Clauses, correct module, plus a transfer impact assessment and supplementary safeguards where required
Technical safeguards	Data minimisation, pseudonymisation, encryption in transit and at rest, EEA region selection, restricted support access and controller-held keys where feasible
Evidence required	DPA, subprocessor list, data-location statement, retention setting, DPF evidence or SCCs, transfer assessment and review date

An EEA hosting-region selection does not by itself prove that no restricted transfer or third-country remote access occurs.

1.3 Section B: Risk and rights

1.3.1 B1. Article 9 special-category data

Special-category data is not necessary for the current tender decision. It may nevertheless appear incidentally in CVs, biographies, expert profiles or free-text attachments, or be inferred from names and contextual information. The system should use detection and redaction before external-model or vector-store calls. Any deliberate use would require both an Article 6 basis and a separate Article 9 condition. If no condition is documented, the data must be excluded or quarantined for human review.

1.3.2 B2. Article 22 automated decision-making

The bid or no-bid output concerns i@work's commercial decision, not a decision producing legal or similarly significant effects on a natural person. Article 22 is therefore not directly triggered on the stated facts. The conclusion changes if Phase II ranks individual consortium experts, applicants or employees in a way that determines access to an opportunity. Human approval must remain genuine, supported by source evidence and able to override the model.

1.3.3 B3. DPIA screening against the nine EDPB criteria

EDPB criterion	Applies?	Reason
Evaluation or scoring	Partly	The system scores tenders and organisations; it should not score identifiable people
Automated decision with legal or similarly significant effect	No on current facts	The final decision is a human-approved company decision
Systematic monitoring	No on current facts	It searches tender and research sources rather than monitoring individuals over time
Sensitive or highly personal data	Not intended	Incidental appearance is possible and requires filtering
Large-scale processing	No on demonstrated scope	The described run concerned a bounded set of tender records, not population-scale personal data
Matching or combining datasets	Yes	Portal, CORDIS, web, internal context and RAG evidence are combined
Vulnerable data subjects	No on current facts	No children, patients, applicants, employees under assessment or dependent service users are intended
Innovative technology	Yes	The architecture combines autonomous agents, ReAct, LangGraph, LLMs and vector retrieval

EDPB criterion	Applies?	Reason
Preventing exercise of a right or use of a service or contract	No	The recommendation does not determine an individual's service or contractual access

Conclusion: Two criteria, dataset combination and innovative technology, are present. Because their personal impact is limited on the stated scope, a full DPIA is not conclusively mandatory solely from the current evidence. A documented DPIA screening is mandatory as an accountability step, and a proportionate DPIA is strongly recommended before production because data is replicated across several systems and potentially transferred outside the EEA. A full DPIA becomes mandatory or substantially more likely if the product introduces person-level scoring, systematic web monitoring, special-category data, CV analysis or legally significant decisions.

1.3.4 B4. Likely data-subject friction points

Right or issue	Likely difficulty	Required design response
Access	Locating a person across prompts, logs, vector namespaces, reports and collaboration tools	Maintain a data lineage key and searchable processing inventory
Rectification	Correcting inaccurate public-source information after it has influenced scoring or a report	Preserve source provenance, version reports and propagate corrections
Erasure	Deleting source data may not remove embeddings, logs, backups or published copies	Implement linked deletion across all stores and record exceptions
Objection	A professional contact may object to processing based on legitimate interests	Provide a review workflow and cease processing unless compelling grounds apply
Transparency	Data is often obtained from public sources rather than directly from the person	Assess Article 14 notice duties and any documented exception carefully
Accuracy and fairness	Public or generated information can be incomplete or outdated	Use authoritative sources, timestamps, confidence indicators and human validation

1.3.5 B5. Controller and processor split

- i@work is controller when it operates the product for its own tender strategy and determines why and how the information is assessed.
- A client is normally controller when it commissions the assessment for its own purpose and instructs i@work. i@work is then processor for the instructed processing.
- i@work becomes controller for any independent analytics, model-training or product-improvement purpose it determines.
- LLM, vector, hosting, collaboration and publication vendors are processors or subprocessors only to the extent that they act on documented instructions.
- Source portals are separate controllers for their own publication and service activities.

1.3.6 B6. Data Processing Agreements

Article 28 DPAs are required with every processor handling personal data, including applicable hosting, LLM, vector, collaboration, storage, notification and network service providers. The i@work-to-client contract must also establish the correct controller-processor chain when i@work processes on behalf of a client. Each DPA should cover instructions, confidentiality, security, subprocessors, rights assistance, breach support, DPIA support, deletion or return, audits and international transfers.

1.4 Section C: Law stacking

1.4.1 C1. AI Act cross-check

The current system is not an Annex III high-risk use because it supports an internal tender decision and does not determine a natural person's legal or similarly significant access to an opportunity. It remains subject to general AI literacy, governance and any applicable Article 50 transparency obligations. Users interacting directly with an AI interface should be informed that it is AI. AI-generated text intended for public-interest publication must be reviewed against the applicable transparency rules. If Phase II introduces recruitment, CV ranking or person-level selection, the classification must be repeated before design or deployment.

1.4.2 C2. ePrivacy check

The backend tender pipeline does not inherently require cookies, tracking pixels or terminal access. Strictly necessary login or session storage may qualify for the narrow exemption under national ePrivacy implementation. Analytics, behavioural tracking, retargeting, fingerprinting or non-essential personalisation in a future user interface requires prior consent where Article 5(3) applies. Legitimate interests under GDPR cannot substitute for required ePrivacy consent.

1.4.3 C3. Data Act check

The core scenario does not concern data generated by a connected product, so the connected-product access provisions are not central. Cloud-switching and portability considerations are relevant to the extent that i@work consumes or later provides data-processing services. The architecture should avoid unnecessary lock-in by maintaining exportable reports, documented schemas, retrievable vector metadata and portable workflow configuration. If the product expands into industrial IoT tender or asset analytics, the Data Act assessment must be reopened.

1.5 Section 2: Client recommendation memo

1.5.1 To: Management and Technical Lead, i@work UG

1.5.2 Subject: GDPR readiness of the EU Tender Autonomous Agent

Bottom line: Go with conditions. The system may proceed as a human-supervised tender decision-support tool, but production use should not begin until the personal-data flow, vendor contracts and enforceable privacy controls are documented.

The present use case is comparatively contained. The agent evaluates tenders and organisational fit, while a human makes the final bid or no-bid decision. It does not decide an individual's employment, credit, public benefit or access to an essential service. GDPR still applies because tender documents, logs and reports can contain professional contact details, user identifiers, IP addresses, named experts and other information relating to identifiable people. Public availability does not remove that information from GDPR.

Three actions should be completed in sequence. First, approve a complete controller, processor and transfer map. Execute Article 28 DPAs with every relevant hosting, LLM, vector, collaboration and publication provider. For each non-EEA transfer, verify current adequacy coverage or implement the correct Standard Contractual Clauses, a transfer assessment and supplementary safeguards. Second, complete a documented DPIA screening and implement a privacy gate before every LLM, Pinecone and publication call. The gate should remove unnecessary names, email addresses, signatures, CV content, credentials and special-category information. Model training or service improvement using operational prompts must remain disabled until a separate purpose and lawful basis are approved. Third, implement retention and rights handling. Prompts, logs, embeddings, reports and collaboration copies need linked deletion, correction and access procedures, with tested owners and deadlines.

Residual risks remain. External models may retain or reproduce information despite minimisation. Erasure can be difficult once data has reached embeddings, backups and multiple publication channels. Vendor subprocessors, transfer mechanisms and hosting access can change after approval. Public-source data may also be inaccurate or used outside the individual's reasonable expectations. These risks cannot be eliminated completely, but they can be reduced through short retention, source provenance, vendor review, access controls, human validation and periodic reassessment.

The recommended release gate is therefore conditional approval by the controller after the above evidence has been completed and tested.

1.6 Reinforcement materials

The accompanying `DPIA_and_Privacy_by_Design_Appendix_EU_Tender_Agent.md` contains:

- A proportionate DPIA outline
- A proposed processor clause for high-risk vendor changes
- The UK GDPR variation
- A privacy-by-design pass, fail or unknown checklist

The required peer assessment is reproduced below and is also available as the standalone `Partner_Peer_Review_Rubric_EU_Tender_Privacy_Audit.md` form. It intentionally remains blank for the actual human partner.

1.7 Appendix: Blank Partner Peer Review Rubric

1.7.1 Option B - Start fresh with a new scenario

PENDING PARTNER REVIEW. Select exactly one scenario before preparing or scoring the audit. Do not combine scenarios or insert generated reviewer feedback.

1.7.2 Scenario commitment

- ☐ **(a) Support-chat LLM fine-tuning:** A B2B software provider proposes training a customer-service model on two years of support conversations containing names, email addresses and complaint narratives.
- ☐ **(b) CV screening with human review:** An HR technology provider ranks applicants from structured and free-text CV information, while a recruiter confirms or overrides the shortlist.
- ☐ **(c) E-commerce personalisation:** A retailer uses first-party cookie information and purchase history for recommendations, with a US analytics provider involved.

Committed scenario: _____

Partner initials: _____ **Commitment date:** _____

1.7.3 Shared fact pattern

Client and business context:

System purpose:

Personal data involved:

Data-subject location and geography:

Non-EU vendor or transfer element:

Agreed fact pattern, five to eight lines:

1.7.4 Review record

Memo author: _____ **Reviewer:** _____

Review date: _____ **Memo title:** _____

1.7.5 Scoring rubric

Use 1 for weak, 2 for adequate and 3 for strong.

Criterion	Score 1 to 3	Reviewer comment
Clear bottom-line recommendation		
Lawful-basis selection is justified		
Top actions are specific and sequenced		
Residual risks are named honestly		
Law stacking addresses the AI Act and ePrivacy		

Total: ____ / 15

1.7.6 Client response

- ☐ Accept the recommendation
- ☐ Flag one concern or challenge one finding
- ☐ Ask the consultant to redesign one section

Explain the selected response in two to three sentences:

1.7.7 Debrief

Where did the audits agree?

Where did they diverge?

Which interpretation was stronger, and why?

1.7.8 Author response to feedback

1.8 References

The audit relies on the following official sources:

- General Data Protection Regulation, Regulation (EU) 2016/679
- EDPB guidance on DPIAs and high-risk processing
- EDPB guidance on international data transfers
- European Commission AI Act regulatory framework
- ePrivacy Directive 2002/58/EC
- European Commission Data Act explanation
- European Commission digital simplification status tracker

The companion references/Official_EU_Legal_Sources.md file provides the expanded source map.